

SimdiaTokens — Complete Guide & Capabilities

The most advanced Microsoft 365 / Outlook email security testing platform.

Version: 5.0 | **Updated:** July 2026 | **Repository:** <https://github.com/simdie/simdiatokens-v2>

PART 1: WHAT IS SIMDIATOKENS? (Capabilities)

Why People Use SimdiaTokens

Organizations need to know if their email security actually works. Normal phishing tests just send fake emails and track clicks. They never show what happens AFTER someone gets tricked — which is where the real damage happens.

SimdiaTokens shows the complete picture: from the moment someone clicks a link, to full access of their email, reading messages, creating hidden rules, intercepting financial emails, and jumping to other people in the same company.

Core Capabilities

1. Silent Email Access (OAuth Token Capture)

- Target clicks a link that looks like a normal Microsoft login
- They sign in normally (including 2FA)
- System silently captures an access token (digital key to their email)
- 90-day access — key auto-renews in background
- No password needed
- Works on all account types (personal hotmail/outlook AND enterprise M365)
- Captures target's IP address and location
- Telegram notification when someone falls for it

2. Browser Fingerprint Cloning (Invisible Access)

- Captures target's browser fingerprint during login
- All email access uses this fingerprint
- Microsoft thinks emails are being read from target's own computer
- No "unusual sign-in" alerts ever triggered
- Zero detection risk

3. Full Email Access

- Three-pane Outlook view (folder list, message list, reading pane)
- All folders: Inbox, Drafts, Sent Items, Deleted Items, Archive, Junk, custom
- Read, send, delete, reply, forward with attachments
- Real-time search across all messages
- Consumer vs enterprise menus (only shows what account supports)

4. Hidden Inbox Rules

- 30+ conditions (subject, sender, body, attachments, importance, size)
- 10+ actions (forward, delete, mark read, move, stop processing)
- Rules fire instantly on server — emails intercepted BEFORE reaching inbox
- Self-destructing rules (fire X times then delete, leaving zero trace)
- Hidden folders (exist in admin panel, invisible in target's Outlook)
- All rules display as "External Mail Filter" in target's Outlook

5. OPSEC (Staying Hidden) — 3 Layers of Protection

Layer 1 — "External Mail Filter" (sender-based, 10 addresses): Auto-deletes emails from Microsoft security senders.

Layer 2 — "Security Update" (subject-based, 35+ keywords): Auto-deletes emails with security-related subjects.

Layer 3 — "Alert Filter" (Office 365 alert-specific): Auto-deletes Office 365 security alerts: - "Creation of forwarding/redirect rule" - "Informational alert has been triggered" - "suspicious inbox rule" - "inbox rule was created"

All rules fire instantly on server. Target never sees security warnings. Backup polling system also deletes alerts that arrived before rules were created.

6. Worker Auto-Recovery System

- System checks if Cloudflare Worker is alive every 60 seconds
- Checks BOTH `/status` AND `/oauth/callback` (detects Cloudflare 403 blocks)
- After 2 failures (~2 min), auto-deploys replacement worker
- Tries same-name re-deploy first (keeps old links working)
- Falls back to new random name if flagged/banned
- Telegram alert sent with new redirect URI to add to Azure
- New OAuth links use new worker automatically via `/api/campaigns/redirect`

7. Anti-Scanner Protection

- Worker script detects Microsoft Safe Links, Defender, EOP scanners
- Detects Googlebot, URL scanners, headless browsers, HTTP libraries
- Scanners get benign "Loading..." page (no OAuth redirect visible)
- Real browsers get JavaScript-based redirect (not HTTP 302)
- Scanners can't follow the redirect, can't see OAuth consent

8. Stable Redirect Links

- OAuth links come in 2 formats:
- **Redirect Link** — short, stable URL on backend (`/api/campaigns/redirect`)
- **Full Microsoft OAuth URL** — raw link with all parameters
- Redirect link never changes — always points to active worker
- Old links continue working even after worker replacement

9. AI-Powered Features

- **Email Mimicking** — learns target's writing style from sent emails
- **Polymorphic Lures** — every email is structurally unique
- **Conversation Hijacking** — injects into active email threads
- **Smart Rule Suggestions** — AI suggests 3-5 interception rules
- **Financial Detection** — scans for 30+ financial keywords, auto-forwards

10. Advanced Features

- **Auto-Re-Harvest** — when token revoked, auto-sends lure from another compromised account in same company
- **Cross-Account Intelligence** — correlates compromised accounts from same organization
- **Silent Calendar Manipulation** — injects fake meetings
- **Calendar Lure Delivery** — OAuth link as "Join Meeting" button (bypasses email security)
- **Teams Chat Delivery** — sends OAuth links via Teams chat (bypasses email security)

- **Deleted Items Management** — view and permanently purge deleted items

11. Contacts with Smart Categorization

- **Enterprise** — business/company emails powered by Office 365
- **Consumer** — Microsoft personal emails (outlook, hotmail, live, msn + 40 international variants)
- **Other Email Service** — non-Microsoft providers (gmail, yahoo, aol, icloud, proton, qq, 163, + 80 more)
- Scans contacts, inbox messages, AND sent items
- Copy filtered email lists with one click

12. Multi-Tenant Super Admin

- One-Click Deploy — automated Worker creation + env config + admin registration
- Deployment cards with username, status, expiration, URLs
- Subscription management (1 day to 90 days + custom)
- Suspend/unsuspend instantly
- Expiration badge on each user's dashboard (date + days remaining)
- Auto-suspend expired accounts
- Railway project creation via API (automated)

13. Security & Encryption

- AES-256-GCM encryption for tokens at rest
- Argon2id password hashing
- JWT authentication (7-day tokens)
- Role-based access (admin, operator, viewer)
- Full audit logging

PART 2: HOW TO USE SIMDIATOKENS (User Guide)

Getting Started

Your Dashboard

When you log in, you'll see: - **Top bar**: Search, expiration badge (shows days remaining), notification bell, theme toggle, user menu - **Sidebar**: Dashboard, Tokens, Inbox, Campaigns,

Rules, Recon, Analytics, BEC, Lure, Activity, Settings - **Main area**: Token table with captured accounts

Capturing Your First Token

Step 1: Generate an OAuth Link

1. Click **Campaigns** in the sidebar
2. Click **Generate OAuth Link**
3. A dialog appears with TWO links:
4. **Redirect Link (Recommended)**: Short URL like `https://your-api.up.railway.app/api/campaigns/redirect`
5. **Full URL**: The complete Microsoft OAuth link
6. Click **Copy Redirect Link** or **Copy Full URL**

Step 2: Send the Link to the Target

Send the link via: - Email - Teams chat - Calendar invite - Any messaging platform

When the target clicks the link: 1. They see Microsoft's real login page 2. They sign in normally (with 2FA if required) 3. Microsoft asks for consent — they click "Accept" 4. They get redirected to their normal Outlook 5. The system captures their access token silently 6. You get a Telegram notification

Step 3: View the Captured Token

1. Go to **Dashboard** or **Tokens**
 2. The target's email appears in the table with:
 3. Email address
 4. Status (ACTIVE)
 5. Account type (Enterprise or Consumer)
 6. IP address and location
 7. Capture time
 8. Click **ONEDRIVE**, **EXCHANGE**, **Contacts**, or **OUTLOOK** buttons for actions
-

Managing Tokens

Token Table Actions

Each token row has buttons: - **EXCHANGE** — Go to inbox rules page - **OUTLOOK** — Open full Outlook email interface - **Contacts** — Extract and categorize all email contacts - **Rules** — Create/manage inbox rules - **ONEDRIVE** — Browse OneDrive files - **Refresh** — Refresh the access token - **Delete** — Delete token (also cleans up Graph rules)

Contacts Extraction

1. Click the **Contacts** button on any token
 2. System scans: address book (500), inbox (200), sent items (200)
 3. Emails categorized as:
 4. **Enterprise** (blue) — business/corporate emails
 5. **Consumer** (purple) — Microsoft personal emails
 6. **Other Email Service** (orange) — gmail, yahoo, etc.
 7. Click **Copy All** to copy filtered email list
 8. Switch between categories using filter buttons
-

Inbox Rules

Creating a Rule

1. Go to **Rules** page (click EXCHANGE on a token)
2. Set conditions:
3. Subject contains specific words
4. Sender contains specific words
5. Body contains keywords
6. Has attachments
7. Importance level
8. Size range
9. Set actions:
10. Forward to (external address)
11. Forward as attachment
12. Redirect to
13. Delete message
14. Permanent delete
15. Mark as read
16. Move to folder (local, invisible in target's Outlook)

17. Stop processing other rules

18. Click **Create Rule**

How Rules Work

- **Graph-synced rules**: Fire instantly on Microsoft's server. Email intercepted before reaching inbox. Target never sees it.
- **Local-only rules**: Background polling checks every 10 seconds for 5 minutes.
- **Self-destructing rules**: Set max fires (e.g., fire 3 times then auto-delete). No trace left.

Graph API Rules

Click **Graph API Rules** tab to see rules that exist in the target's actual Outlook. These are the rules created by the system (including OPSEC auto-delete rules).

Outlook Interface

Accessing the Mailbox

1. Click **OUTLOOK** on any token
2. Full Outlook interface opens with:
3. Folder sidebar (Inbox, Sent Items, Drafts, etc.)
4. Message list
5. Reading pane

Email Operations

- **Read**: Click any email to view full content
 - **Compose**: Click "New Mail" button
 - **Reply/Forward**: Use reply buttons on any email
 - **Delete**: Select emails and delete
 - **Move**: Drag emails between folders
 - **Search**: Use search bar to filter messages
 - **All folders**: Inbox, Drafts, Sent Items, Deleted Items, Archive, Junk, custom
-

OPSEC (Staying Hidden)

Automatic Protection

When a token is captured, the system AUTOMATICALLY: 1. Creates 3-4 inbox rules in the target's Outlook: - "External Mail Filter" — deletes emails from 10 Microsoft security senders - "External Mail Filter 2" — deletes from 4 more security senders - "Security Update" — deletes emails with 35+ security-related subjects - "Alert Filter" — deletes Office 365 alert emails (forwarding rule alerts, etc.) 2. All rules fire instantly — target never sees security warnings 3. Backup polling deletes any alerts that arrived before rules were created 4. All rules named "External Mail Filter" (disguised)

What Gets Auto-Deleted

- "New app connected to your account" notifications
 - "Suspicious sign-in" alerts
 - "Password changed" notifications
 - "Creation of forwarding/redirect rule" alerts (NEW)
 - "Informational alert" emails from Office 365 (NEW)
 - Any email from security@microsoft.com, office365alerts@microsoft.com, etc.
-

Campaigns

Generating Links

- **Redirect Link (Recommended):** `https://your-api.up.railway.app/api/campaigns/redirect`
- Short, stable, always works
- Never changes even if worker is replaced
- **Full URL:** Complete Microsoft OAuth link
- Direct, no redirect needed
- Useful for embedding in custom HTML

Deploy Worker Button

If the Cloudflare Worker needs redeployment: 1. Go to Campaigns page 2. Click "Deploy Worker" 3. System pushes the latest worker script to Cloudflare 4. Worker is immediately live

Reconnaissance

What You Can See

For each captured token, click **Recon** to view: - **User Profile**: Name, title, department, office, phone, company - **Manager**: Who the target reports to - **Direct Reports**: Who reports to the target - **Group Memberships**: All Azure AD groups - **Organization**: Tenant name, verified domains

Analytics

Dashboard Metrics

- **Token Health**: Active vs expired vs revoked
- **Operation Success Rate**: Percentage of successful captures
- **Token Activity Timeline**: Created vs revoked over time
- **Action Distribution**: Breakdown of all system actions
- **Top Domains**: Most compromised organizations
- **Activity Feed**: Live audit log

Filtering

- 24 hours, 7 days, 30 days, or custom date range
-

Settings

Available Settings

- **AI Configuration**: OpenAI API key, model, max tokens
 - **Encryption Management**: Set/change master passphrase
 - **Stealth Mode**: Toggle stealth configuration
 - **Rules Management**: View all rules across all tokens
 - **Purge Expired Tokens**: Bulk delete old tokens
 - **Password Change**: Change admin password
-

Worker Health Monitor

How It Works

- System checks worker health every 60 seconds
- Tests both `/status` (script running) and `/oauth/callback` (not blocked by Cloudflare)
- After 2 consecutive failures (~2 minutes):
- Tries re-deploying to same worker name (fixes crashes)
- If still flagged, deploys new worker with random name
- Updates database with new active worker
- Sends Telegram alert with new redirect URI
- New OAuth links automatically use the new worker
- Old links via `/api/campaigns/redirect` also work

Telegram Alerts

When a worker is replaced, you receive: - Old worker name (flagged) - New worker name - New redirect URI to add to Azure Portal - Step-by-step instructions

To enable: Set `TELEGRAM_BOT_TOKEN` and `TELEGRAM_CHAT_ID` on Railway

Super Admin Panel

Accessing

- Go to `https://simdiatokens-frontend.vercel.app/super-admin`
- Login with super admin credentials

Managing Deployments

- **Create:** Use One-Click Deploy form
- **View:** Cards show username, status, expiration, URLs
- **Edit:** Update subscription, suspensions, URLs
- **Suspend:** Instantly block client login
- **Delete:** Remove deployment (Graph rules also cleaned up)

One-Click Deploy

Automates: - Cloudflare Worker creation - Railway project creation (via API) - Environment variable setup - Admin registration with 30-day default subscription - Worker subdomain enablement - Azure redirect URI (manual add required)

Subscription Management

- Preset durations: 1 day, 3 days, 1 week, 30/60/90 days
 - Custom duration input
 - When extended, system automatically unsuspends user on their backend
 - Expired accounts auto-suspended on login attempt
-

Troubleshooting

"SUBSCRIPTION EXPIRED" on login

Super admin needs to extend your subscription: 1. Super admin panel → find your deployment 2. Edit → set new usage_days or expires_at 3. System syncs to your backend and unsuspends you

"Failed to fetch" on login

Frontend can't reach backend. Check: - Backend URL is correct on Vercel
(`NEXT_PUBLIC_API_URL`) - Backend is running on Railway - No CORS issues

OAuth link doesn't capture token

1. Check if worker is flagged: visit worker URL `/status`
2. Check Railway deploy logs for `[exchange]` errors
3. Verify `CLIENT_SECRET` is the secret VALUE (starts with `XZI8Q~` or `yEz8Q~`), not the Secret ID
4. Verify redirect URI is added to Azure Portal

Worker flagged by Cloudflare

- System auto-detects and replaces within ~2 minutes
- Telegram alert sent with new redirect URI
- Add new URI to Azure Portal manually
- New links work automatically

Rules not showing / stale rules

- When a token is deleted, system now cleans up Graph API rules
- Re-capture the same email and rules page will be clean

Missing folders (e.g., Sent Items)

- System now fetches up to 100 folders (was 10)
 - Enterprise mailboxes with 11+ folders show all folders
-

SimdiaTokens v5.0 — Complete Platform Guide